

SAE4 2026

GAILLARD Nicolas – nicolas.gaillard@gantois.com

php

 Symfony



FORTINET®

INTRODUCTION

OBJECTIFS DE LA SAE

- Auditer un applicatif existant
 - Corriger les défauts constatés
 - Collaborer efficacement sur un projet
 - Rendre compte à différents interlocuteurs
-
- Conteneuriser un site web
 - Approfondissements

3 AXES DE TRAVAIL

- Performance
- Robustesse
- Sécurité

CONSIGNES

TRAVAIL DE GROUPE

- Répartir les tâches
- Utiliser Git / Git LFS / Gitlab
- Etablir un planning

RENDUS

- Rendus sur Arche
- Mise en page des documents
- Respect des délais

RENDUS

PHASES 1, 2 ET 3 (22 FEVRIER)

- Rapport d'audit
- Proposition commerciale
- Environnement Git

PHASES 4 ET 5 (5 ET 12 JUIN)

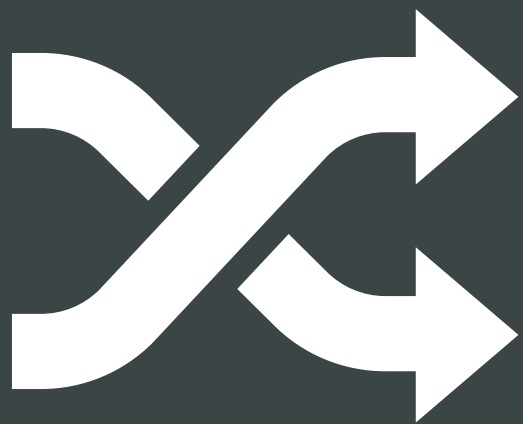
- Application modifiée
- Rapport
- Présentation orale

NOTATIONS

	C1	C2	C3	C4	C5	C6	Total
Développement	$\frac{35}{6}$	$\frac{35}{6}$	$\frac{35}{6}$	$\frac{35}{6}$	$\frac{35}{6}$	$\frac{35}{6}$	35
Mathématiques	$\frac{10}{4}$	$\frac{10}{4}$	$\frac{10}{4}$	$\frac{10}{4}$			10

NOTATIONS (ALTERNANTS)

	Total
Développement	35
Mathématiques	10

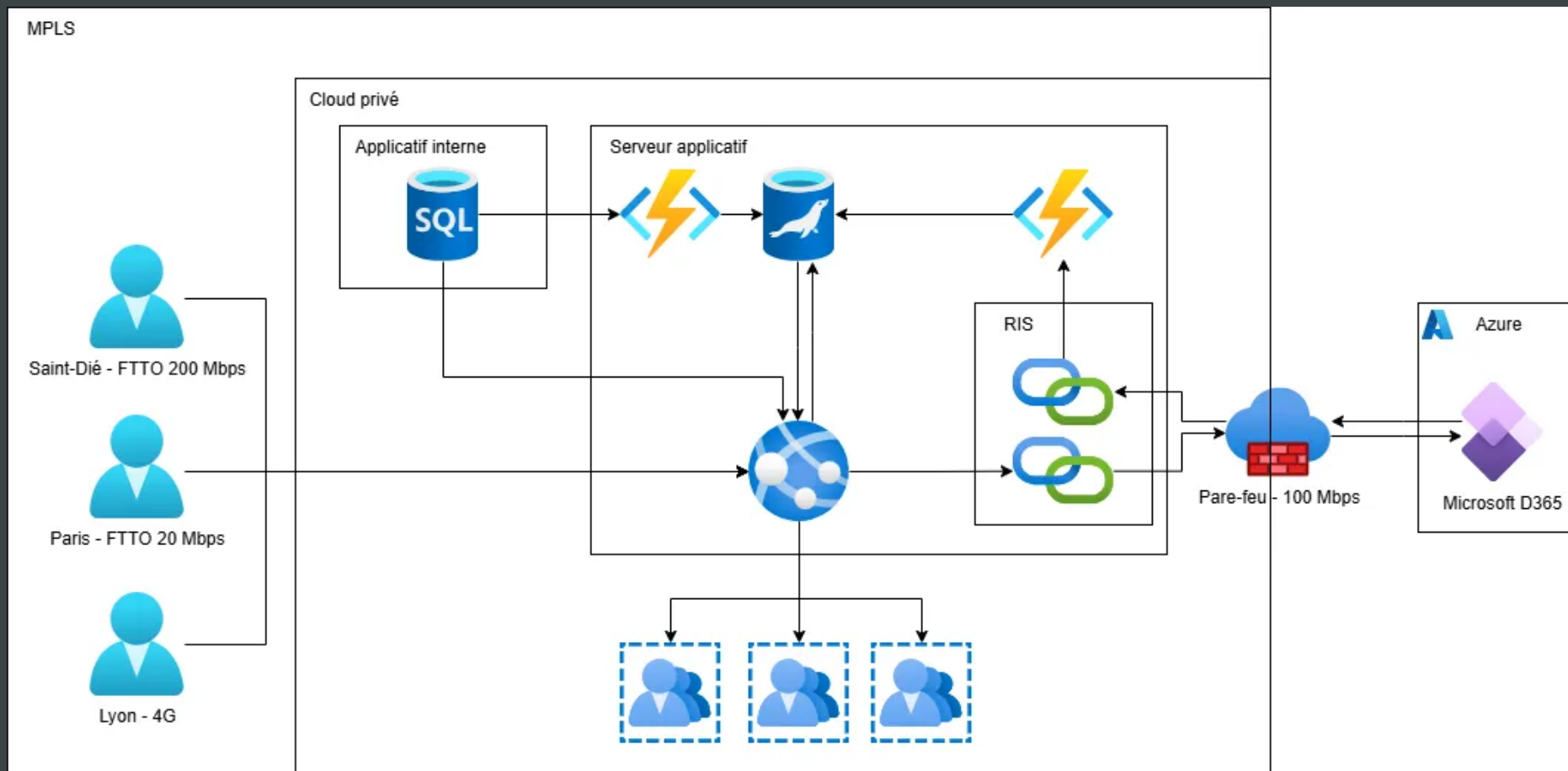


INFRA, RÉSEAU ET CADRES RÉGLEMENTAIRES

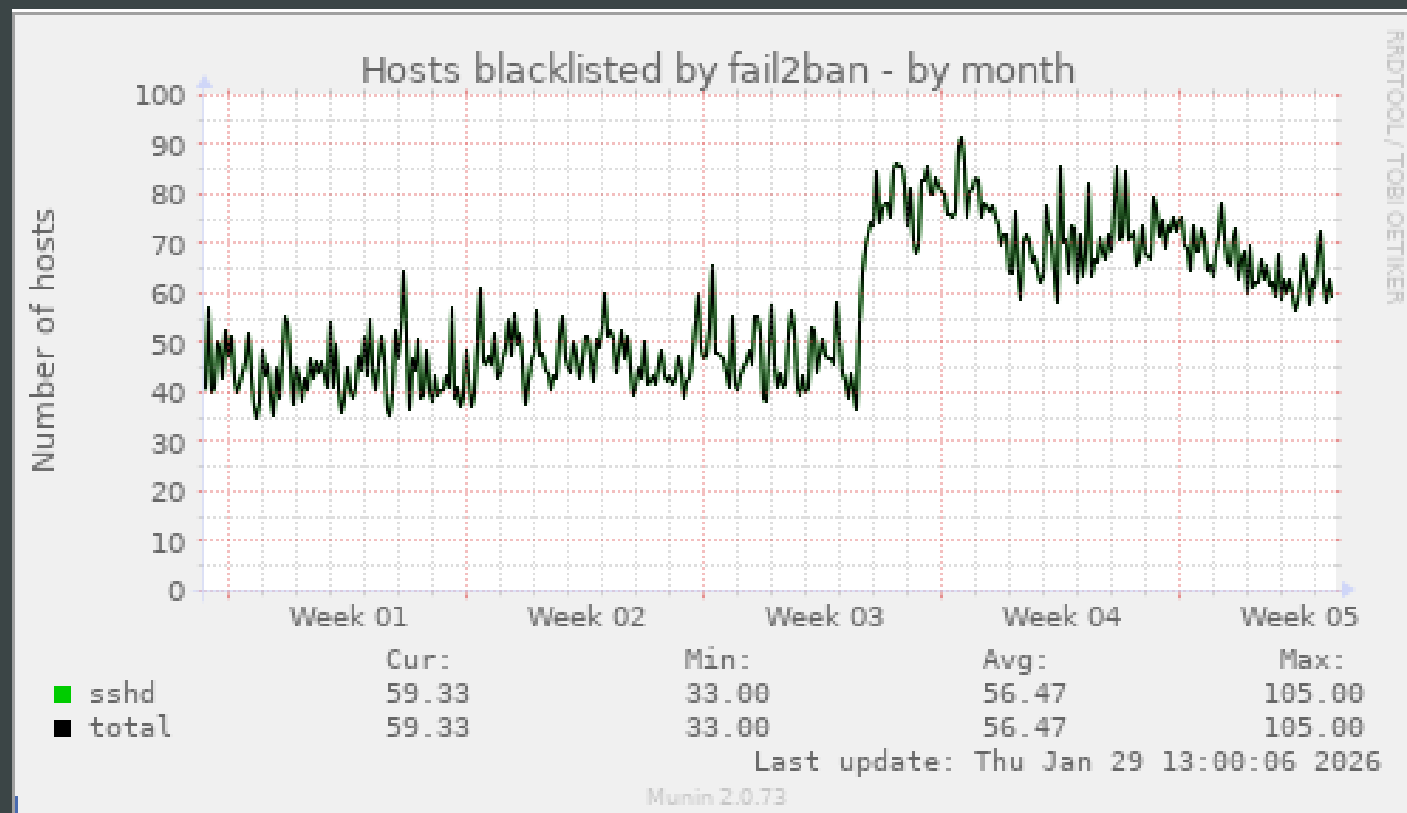
DIVERSITÉ DES INFRA ET RÉSEAU

- Types d'hébergement
- Emplacement
- Type de réseau
- Technologie réseau

EXEMPLE ET ENJEU



ATTAQUES PERMANENTES



CADRES RÉGLEMENTAIRES

- RGPD
- ISO 27001
- NIS 2
- RGAA 4 / EN 301 549 V2.1.2 / WCAG 2.1 A et AA

ANALYSE DE L'EXISTANT

POURQUOI

- Ajouter des fonctionnalités
- Corriger des bugs et failles de sécurité
- Maintenir en condition opérationnelle
- Réduire la dette technique
- Refondre une application

QUOI

CODE

- Trouver le(s) point(s) d'entrée(s)
- Déterminer les dépendances
- Détecter les anomalies

BASE DE DONNÉES

- Schématiser sa structure
- Identifier les liaisons
- Vérifier l'intégrité
- Vérifier les performances

COMMENT

- Installer l'application
- Utiliser l'application
- Interpréter le code et le schéma de base de données
- Lire la documentation
- Echanger avec les créateurs
- Utiliser les outils à votre disposition

OUTILS DISPONIBLES

- Profiler
- Debugger
- IDE
- Rector / Psalm / PHPStan
- IA

DEBUGGER

```
public static function reset()
{
    self::$_registry = array();
    self::$_app = null;
    self::$_useCache = array();
    self::$_objects = null;
    self::$_isDownloader = false;
    self::$_isDeveloperMode = false;
    // do not reset $headersSentThrowsException
}

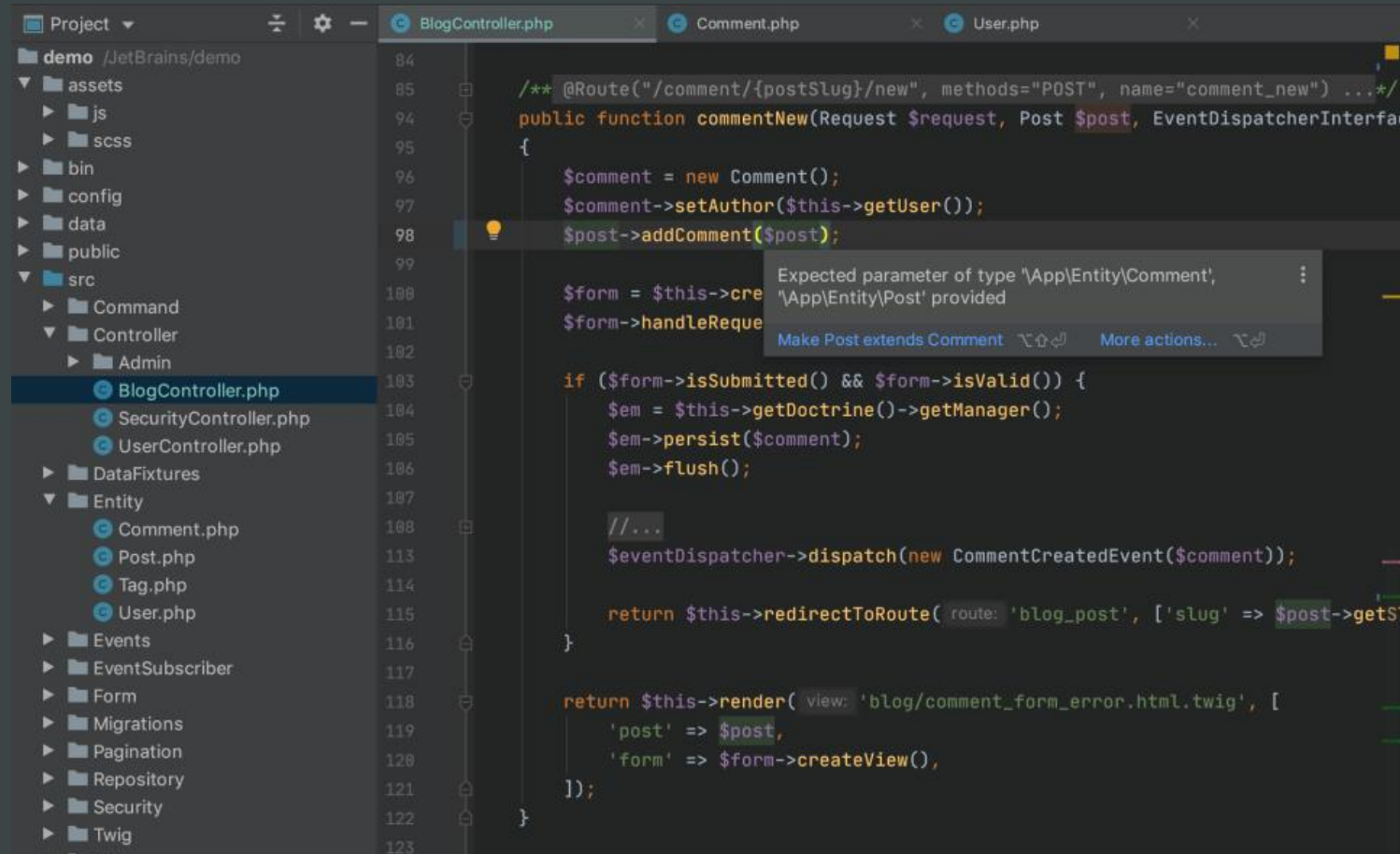
/**
 * Register a new variable
 *
 * @param string $key
 * @param mixed $value
 * @param bool $graceful
 */
public static function register($key, $value, $graceful = false)
{
    if(isset(self::$_registry[$key])) {
        if ($graceful) {
            return;
        }
        Mage::throwException('Mage registry key "'.$key.'" already
exists');
    }
    self::$_registry[$key] = $value;
}

public static function unregister($key)
{
    if (isset(self::$_registry[$key])) {
        if (is_object(self::$_registry[$key]) && (method_exists(se
lf::$_registry[$key], '__destruct')) {
            self::$_registry[$key]->__destruct();
        }
        unset(self::$_registry[$key]);
    }
}

/**
 *
 */
}
```

```
<?
$command = 'feature_set'
$command = 'feature_set'
$command = 'feature_set'
~
~
~
WATCH WINDOW
[ Function Keys ]
<F1>  resize           | [ Normal Mode ]
<F2>  step into       | |e eval
<F3>  step over        |
<F4>  step out         |
<F5>  run              | [ Command Mode ]
<F6>  quit debugging   | :Bp toggle break
<F11> get all context  | :Up stack up
<F12> get property at | :Dn stack down
cursor
HELP WINDOW
0 Mage::register() /var/www/magento/app/Mage.php:11
1 require_once() /var/www/magento/app/Mage.php:36
2 {main} /var/www/magento/index.php:43
~
~
~
STACK WINDOW
20 : send ==> stack_get -i 20
+-- 3 lines: 20 : rcv <== <?xml version="1.0" e
21 : send ==> step_into -i 21
+-- 3 lines: 21 : rcv <== <?xml version="1.0" e
22 : send ==> stack_get -i 22
+-- 3 lines: 22 : rcv <== <?xml version="1.0" e
23 : send ==> step_over -i 23
+-- 3 lines: 23 : rcv <== <?xml version="1.0" e
24 : send ==> stack_get -i 24
+-- 3 lines: 24 : rcv <== <?xml version="1.0" e
TRACE WINDOW
```

IDE



ANALYSE DE CODE STATIQUE

```
/**  
 * @param int $i  
 * @return array<string>  
 */  
function takesAnInt($i)  
{  
    return [$i, "hello"];  
}
```

psalm: InvalidReturnType: The declared return type 'array<array-key, string>' for takesAnInt is incorrect, got 'array{int, string(hello)}'

```
$data = ["some text", 5];  
takesAnInt($data[0]);
```


IA ET DEMONSTRATION



PISTES DE TRAVAIL

MOTS DE PASSE – QUEL ALGORITHME

- MD5
- SHA1
- SHA256
- Bcrypt
- Argon2

MOTS DE PASSE – COMPARAISON (2024)

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols	Hardware
8	Instantly	6 secs	24 mins	2 hours	4 hours	RTX 2080
8	Instantly	6 secs	13 mins	52 mins	2 hours	RTX 3090
8	Instantly	1 sec	5 mins	22 mins	59 mins	RTX 4090
8	Instantly	Instantly	2 mins	7 mins	19 mins	A100 x8
8	Instantly	Instantly	1 min	5 mins	12 mins	A100 x12
8	Instantly	Instantly	Instantly	Instantly	1 sec	A100 x10,000 (ChatGPT)

Max time required to crack randomly generated 8-character MD5 password hashes of various complexity on different hardware.

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols	Hardware
8	2 hours	4 months	92 years	375 years	989 years	RTX 2080
8	17 mins	4 weeks	18 years	72 years	189 years	RTX 3090
8	9 mins	2 weeks	9 years	38 years	99 years	RTX 4090
8	2 mins	2 days	2 years	7 years	17 years	A100 x8
8	1 min	2 days	1 year	4 years	12 years	A100 x12
8	Instantly	3 mins	11 hours	2 days	5 days	A100 x10,000 (ChatGPT)

Max time required to crack randomly generated 8-character bcrypt password hashes set to 32 iterations of various complexity on different hardware.

MOTS DE PASSE – BCRYPT(10)

Number of Characters	Numbers Only	Lowercase Letters	Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters	Numbers, Upper and Lowercase Letters, Symbols
4	Instantly	Instantly	Instantly	Instantly	Instantly
5	Instantly	Instantly	57 minutes	2 hours	4 hours
6	Instantly	46 minutes	2 days	6 days	2 weeks
7	Instantly	20 hours	4 months	1 year	2 years
8	Instantly	3 weeks	15 years	62 years	164 years
9	2 hours	2 years	791 years	3k years	11k years
10	1 day	40 years	41k years	238k years	803k years
11	1 weeks	1k years	2m years	14m years	56m years
12	3 months	27k years	111m years	917m years	3bn years
13	3 years	705k years	5bn years	56bn years	275bn years
14	28 years	18m years	300bn years	3tn years	19tn years
15	284 years	477m years	15tn years	218tn years	1qd years
16	2k years	12bn years	812tn years	13qd years	94qd years
17	28k years	322bn years	42qd years	840qd years	6qn years
18	284k years	8tn years	2qn years	52qn years	463qn years

**Time it takes
a hacker to
brute force
your password
in 2025**

Hardware: 12 x RTX 5090
Password hash: bcrypt (10)



Hive Systems

Read more and download at
hivesystems.com/password

MOTS DE PASSE - RECOMMANDATIONS

- Ajouter un critère de complexité minimum
- Mettre en place une solution contre le bruteforce
- Utiliser password_needs_rehash

```
try {  
    $pdo = new PDO("mysql:host=$host;dbname=$database;charset=utf8", $user, $password);  
    $pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);  
    // Test de connexion  
    // echo "<p style='color: green;'>Connexion réussie à la base de données !</p>";  
} catch (PDOException $e) {  
    die("<p style='color: red;'>Erreur de connexion : " . $e->getMessage() . "</p>");  
}
```

GESTION DES ERREURS

- Ne pas afficher un message « détaillé » à l'utilisateur
- Ajouter un handler global (`set_error_handler` / `set_exception_handler`)
- Logger les erreurs dans un fichier, envoyer un e-mail, ...

⓪ accept-ranges: bytes
⓪ age: 55
alt-svc: h3=":443";ma=86400,h3-29=":443";ma=86400,h3-27=":443";ma=86400
⓪ cache-control: max-age=60
⓪ content-encoding: br
⓪ content-length: 2126
⓪ content-security-policy: default-src 'self' curl.haxx.se www.curl.se curl.se; style-src 'unsafe-inline' 'self' curl.haxx.se www.curl.se curl.se; require-trusted-types-for 'script';
⓪ content-type: text/html
⓪ date: Tue, 27 Jan 2026 17:41:00 GMT
⓪ etag: "1e14-64868aefcc6fe"
⓪ expires: Sat, 17 Jan 2026 22:53:52 GMT
⓪ last-modified: Thu, 15 Jan 2026 08:05:09 GMT
⓪ server: nginx/1.27.5
⓪ strict-transport-security: max-age=31536000
⓪ vary: Accept-Encoding
⓪ via: 1.1 varnish, 1.1 varnish
x-cache: HIT, HIT
x-cache-hits: 2992, 0
⓪ x-content-type-options: nosniff
X-Firefox-Spdy: h2
⓪ x-frame-options: SAMEORIGIN
x-served-by: cache-bma-essb1270028-BMA, cache-par-lfpb1150060-PAR
x-timer: S1769535660.109267,VS0,VE27

VERSION DES LOGICIELS

- Masquer les versions dans les entêtes HTTP
- Masquer le logiciel si possible (entêtes / URL)
- Utiliser des versions maintenues (PHP 8.4+, ...)

JETON CSRF

- Protection contre les attaques CSRF
- Jeton unique par utilisateur
- Possibilité de le rendre unique par formulaire

BASE DE DONNÉES

- Utilisation de requêtes préparées
- Stockage de la configuration
- Utilisation d'un singleton

BASE DE DONNÉES

- Utilisation de requêtes préparées
- Stockage de la configuration
- Utilisation d'un singleton

```
BEGIN
```

```
    UPDATE electeur SET vote = 1 WHERE id = user;
```

```
    INSERT INTO vote(candidat) VALUES (candidat);
```

```
END;
```

BASE DE DONNÉES

- Utilisation de requêtes préparées
- Stockage de la configuration
- Utilisation d'un singleton
- Utilisation de transaction
- Limitation des accès

BASE DE DONNÉES

- Modéliser en forme normale
- Avoir des index adaptés
- Eviter le SELECT *
- Optimiser côté application (Mode PDO par exemple)
- Profiter des clés étrangères
- Ecrire correctement les jointures


```
<?php
```

```
$pdo = new PDO("mysql:host=localhost;dbname=root", "root", "");
```

```
$stmt = $pdo->prepare("INSERT INTO user(login, password, email) VALUES(:login, :password, :email)");
```

```
$stmt->execute([...]);
```

```
header('Location:index.php');
```

GESTION DE LA CONFIGURATION

- Gestion par des variables d'environnement
- Ou un fichier « sensible » hors VCS (.env.local, config.php)
- Toujours documenté

GitHub a détecté 39 millions de secrets en 2024 et va encore améliorer ses outils de détection

📅 03/04/2025 👤 Florian BURNEL 💬 0 commentaire 🏷️ Cybersécurité, GitHub

En 2024, GitHub a détecté plus de 39 millions de secrets exposés dans des dépôts publics, dont des clés API et des identifiants sensibles. Face à cette menace, la plateforme annonce des améliorations pour aller plus loin dans la détection. Faisons le point.

GESTION DES DÉPENDANCES

- Utiliser un gestionnaire de paquets
- Spécifier les versions compatibles de PHP
- Définir les extensions nécessaires

CVE-2024-3094 Detail

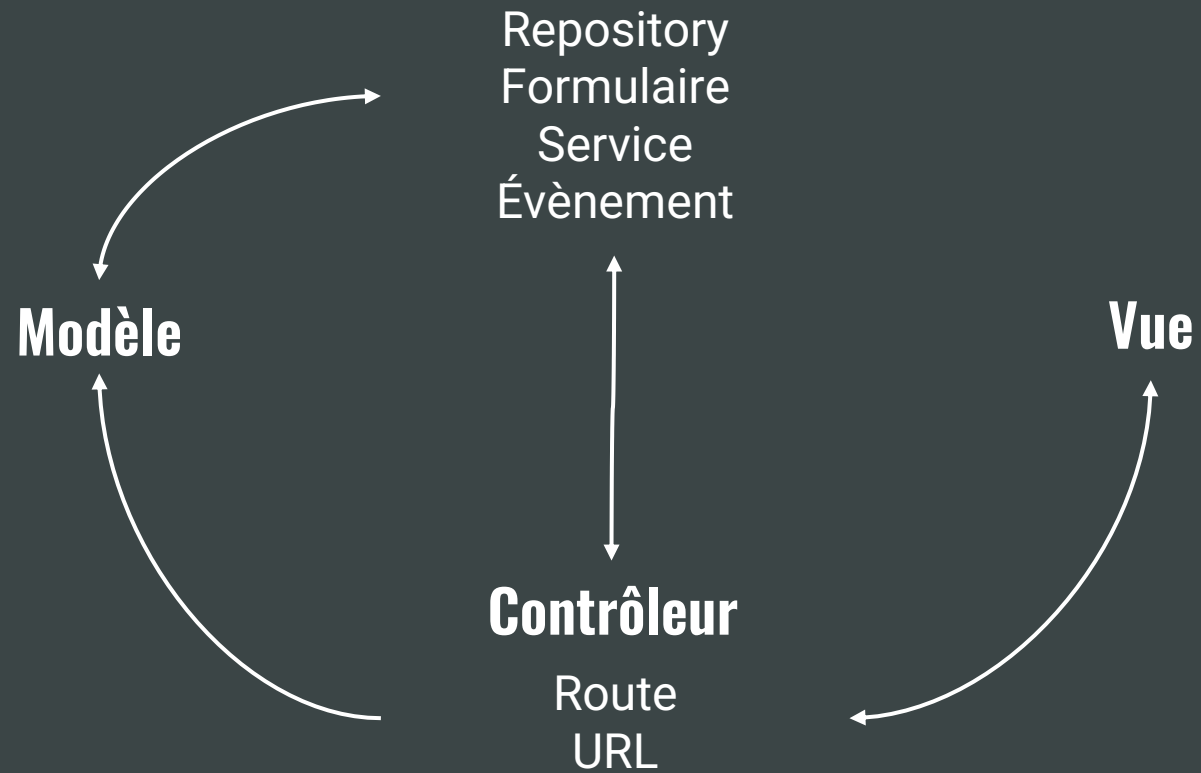
MODIFIED

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Malicious code was discovered in the upstream tarballs of xz, starting with version 5.6.0. Through a series of complex obfuscations, the liblzma build process extracts a prebuilt object file from a disguised test file existing in the source code, which is then used to modify specific functions in the liblzma code. This results in a modified liblzma library that can be used by any software linked against this library, intercepting and modifying the data interaction with this library.

ARCHITECTURE MVC



GESTION DES DOCUMENTS

- Protéger l'accès selon la confidentialité
- Ne pas exposer directement via le serveur web
- Valider les informations essentielles
- Stocker les fichiers avec un hash

Photo booth flaw exposes people's private pictures online

by Danny Bradbury | December 16, 2025



Photo booths are great. You press a button and get instant results. The same can't be said, allegedly, for the security practices of at least one company operating them.

A security researcher spent weeks trying to warn a photo booth operator about a vulnerability in its system. The flaw reportedly exposed hundreds of customers' private photos to anyone who knew where to look.

The researcher, who goes by the name Zeacer, said that a website operated by photo kiosk company Hama Film allowed anyone to download customer photos and videos without logging in. The Australian company provides photo kiosks for festivals, concerts, and commercial events. People take a snap and can both print it locally and also upload it to a website for retrieval later.

VALIDATION DES DONNÉES

- Ne pas faire confiance au client
- Toujours valider côté serveur

Two students discovered a security flaw in over a million internet-connected laundry machines that could allow laundry for free.

[CSC ServiceWorks](#) is a company that provides laundry services and air vending solutions for multifamily housing, academic institutions, hospitality, and other commercial sectors. They manage and operate many internet-connected laundry machines and systems, offering services such as coin and card-operated laundry machines, mobile payment solutions, and maintenance support.

Two students, Alexander Sherbrooke and Iakov Taranenko, from UC Santa Cruz discovered a vulnerability impacting over a million internet-connected laundry machines used in residences and college campuses worldwide. A remote attacker can exploit this vulnerability to remotely send commands to the laundry machines, allowing laundry for free. The duo reported the flaw to the vendor earlier this year, but they claim the company has yet to fix it.

CODE - NETTOYAGE

- Code inutilisé
- Code inaccessible
- Code déprécié
- Factorisation / Découpage
- Imbrications

CODE - DOCUMENTATION

- Fonctions
- Point(s) d'entrées
- Configuration
- Installation

RGPD – MOT DE PASSE OUBLIÉ

- Protection contre le bruteforce
- Message générique lors de la demande
- Temps non différencié selon les cas
- Générer un token (lien) avec une durée de validité

HTTPS – AMÉLIORATIONS

▼ En-têtes de la réponse (898 o) Texte brut

- accept-ranges: bytes
- age: 55
- alt-svc: h3=":443";ma=86400,h3-29=":443";ma=86400,h3-27=":443";ma=86400
- cache-control: max-age=60
- content-encoding: br
- content-length: 2126
- content-security-policy: default-src 'self' curl.haxx.se www.curl.se curl.se; style-src 'unsafe-inline' 'self' curl.haxx.se www.curl.se curl.se; require-trusted-types-for 'script';
- content-type: text/html
- date: Tue, 27 Jan 2026 17:41:00 GMT
- etag: "1e14-64868aefcc6fe"
- expires: Sat, 17 Jan 2026 22:53:52 GMT
- last-modified: Thu, 15 Jan 2026 08:05:09 GMT
- server: nginx/1.27.5
- strict-transport-security: max-age=31536000
- vary: Accept-Encoding
- via: 1.1 varnish, 1.1 varnish
- x-cache: HIT, HIT
- x-cache-hits: 2992, 0
- x-content-type-options: nosniff
- X-Firefox-Spdy: h2
- x-frame-options: SAMEORIGIN
- x-served-by: cache-bma-essb1270028-BMA, cache-par-lfpb1150060-PAR
- x-timer: S1769535660.109267,VS0,VE27

PERFORMANCES HTTP

- Compresser le contenu envoyé (statique / dynamique)
- Optimiser les fichiers
- Combiner les fichiers
- Charger les images à la demande
- Utiliser les CDN
- Mettre en cache les assets

MISE EN CACHE

```
⓪ cache-control: max-age=60
⓪ content-encoding: br
⓪ content-length: 2126
⓪ content-security-policy: default-src 'self' curl.haxx.se www.curl.se curl.se; style-src 'unsafe-inline' 'self'
  curl.haxx.se www.curl.se curl.se; require-trusted-types-for 'script';
⓪ content-type: text/html
⓪ date: Tue, 27 Jan 2026 17:41:00 GMT
⓪ etag: "1e14-64868aefcc6fe"
⓪ expires: Sat, 17 Jan 2026 22:53:52 GMT
⓪ last-modified: Thu, 15 Jan 2026 08:05:09 GMT
```

HTTP/2 ET HTTP/3

- HTTP/2 : Preload des assets
- HTTP/2 : Multiplexage des requêtes
- HTTP/3 : Basé sur le protocole QUIC (UDP)
- QUIC : Sécurité sur la couche de transport

PERFORMANCE SERVEUR

- Optimiser la configuration PHP
- Utiliser OPCache (PHP)
- Optimiser l'autoload Composer
- Optimiser les communications entre le serveur web et PHP
- Optimiser les conditions
- Optimiser la base de données
- Utiliser les bons algorithmes au bon moment

TESTS

- Par-dessus l'analyse statique
- Réponse au cahier des charges (TDD)
- Non-régression
- PHPUnit pour PHP

LES DIFFÉRENTS TESTS

- Tests unitaires
- Tests d'intégrations
- Tests de bout en bout
- Tests d'acceptation / de recette
- Tests de performance

ACCESSIBILITÉ

ACCESSIBILITÉ - INTRODUCTIONS

- Basé sur RGAA 4
- Utilisation d'attributs ARIA
- 13 thématiques
- Focus sur certaines thématiques et certains critères

ACCESSIBILITÉ – IMAGES

- 9 critères
- Présence d'une alternative textuelle (sauf si décoration)
- Alternative qui doit être pertinente
- Si l'image sert de CAPTCHA, présence d'une solution alternative

ACCESSIBILITÉ - COULEURS

- 3 critères
- La couleur ne doit pas être le seul indicateur porteur d'informations
- Le contraste entre texte et arrière-plan doit être élevé

ACCESSIBILITÉ - TABLEAUX

- 8 critères
- La linéarisation du contenu est cohérente
- Les balises de titre, si présente, sont cohérentes
- Les entêtes de colonnes et **lignes** sont présents

ACCESSIBILITÉ – ÉLÉMENTS OBLIGATOIRES

- 10 critères
- Présence d'un DOCTYPE, d'un titre, du langage de la page
- Respect du format du type de document
- Les balises ne servent pas que à la présentation

ACCESSIBILITÉ – STRUCTURE DE L'INFORMATION

- 4 critères
- Présence de header / nav / main / footer
- Structure des titres logiques

ACCESSIBILITÉ – PRÉSENTATION DE L'INFORMATION

- 14 critères
- Balises et attributs de style non utilisé (sauf cas spécifiques)
- Sans CSS, le texte porteur d'information doit rester présent
- Lien visible si leur nature est pas évidente

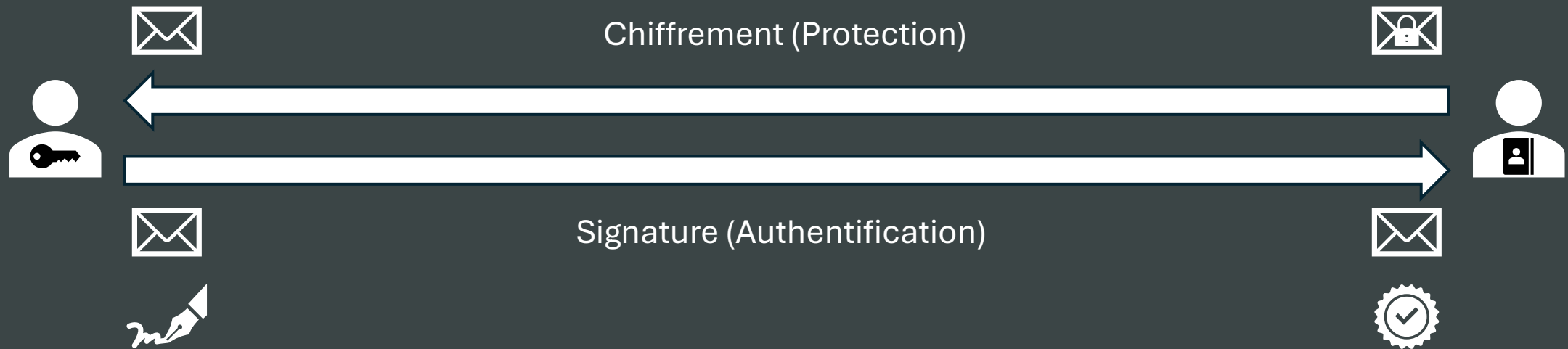
ACCESSIBILITÉ - FORMULAIRES

- 13 critères
- Présence d'un label
- Regroupement des champs de même nature
- Champs requis sont identifiés
- L'auto-complétion est permise et guidée

RÉFLEXIONS SUR LA SAE3

- Format des e-mails
- Double authentification
- Concurrence
- Séparation bulletin / émargement
- Empreinte de l'application, des électeurs, ...

RÉFLEXIONS SUR LA SAE3



PHAR – PHP ARCHIVE

- Distribution simplifiée
- Empreinte/Signature de l'application
- Intégration dans une CI/CD
- Outils tiers comme Phing pour la construire

CONTENEURISATION

POURQUOI UTILISER UN CONTENEUR

- Multiples environnements (dev/test/staging/prod)
- Multiplication des langages, bases de données, frameworks, ...
- Multiplication des emplacements, ...

OBJECTIF DU CONTENEUR

- Encapsuler le logiciel et garantir son fonctionnement partout
- Eviter le « ça marche chez moi »
- Rendre opérationnel un intervenant rapidement

DIFFÉRENCES AVEC UNE VM

- Le conteneur contient que ce qui est nécessaire à l'application
- Isolation des ressources (système de fichier, base de données, ...)
- Amélioration de performances
- Intégrable dans la CI/CD
- Simplification du déploiement

DOCKER

- Technologie qui a popularisé l'utilisation des conteneurs (2013)
- Projet interne devenu open source
- Images immuables
- Registres d'images (public ou privé)
- Conteneur : Instance d'une image
- Docker Compose pour « orchestrer » plusieurs conteneurs

DIFFICULTÉS POSSIBLES DE DOCKER

- Gestion des données persistantes
- Gestion des UID/GID
- Sécurisation de Docker

DOCKERFILE

- Création d'images personnalisés
- Fonctionne par couche

- Ajout de fichier
- Exposition de port
- Lancement de commande
- ...

DOCKER COMPOSE

- Un fichier pour définir l'ensemble des conteneurs à lancer
- Basé sur des images de registre ou modifiées
- Utile en environnement de développement



FRAMEWORK / SYMFONY

POURQUOI UTILISER UN FRAMEWORK

- Coder mieux et plus vite
- Ne pas réinventer la roue
- Se concentrer sur le métier
- Simplifier la maintenance

POURQUOI UTILISER SYMFONY

- Stable et reconnu
- Utilisé par des grosses références
- Composants et framework

PRISE EN MAIN DE SYMFONY

- Très bonne documentation
- Documentation sur le site internet
- Formation en vidéo (SymfonyCasts / Grafikart / Dyma)
- Livre Symfony
- ...

LES COMPOSANTS SYMFONY

- Console / Traducteur / Validateur / ...
- Utilisable en dehors du framework
- Framework fait communiquer les composants

STRUCTURE D'UN PROJET SYMFONY

- Respect du MVC (Entité Doctrine / Contrôleur / Vue Twig)
- Deux points d'entrées (Console / Requête)
- Fonctionne avec des services
- Système d'événements

INJECTION DE DÉPENDANCES

- Charge au besoin les services
- Résout les dépendances entre les services
- Garanti un singleton

SYMFONY ET LA SAE - BASES

- Architecture MVC
- Intégration avec Docker
- Profiler pour « optimiser » l'application

SYMFONY ET LA SAE - SÉCURITÉ

- Système d'authentification standard
- Renforcement des mots de passe depuis d'autres algorithmes
- Rôles pour les gérer des droits d'accès basiques
- Voter pour faire des règles complexes d'accès
- Protection CSRF

SYMFONY ET LA SAE - DOCTRINE

- Singleton (Service)
- Protection des requêtes
- Schéma cohérent
- Gestion des transactions

SYMFONY ET LA SAE - DIVERS

- Formulaires avec validation
- Composant « rate limiter »
- Débogage des e-mails
- Envoi asynchrone des e-mails
- Gestion des erreurs

SYMFONY ET LA SAE – DEMO (5H)

